

Week 5- Data Governance

Dr. Smitha K G

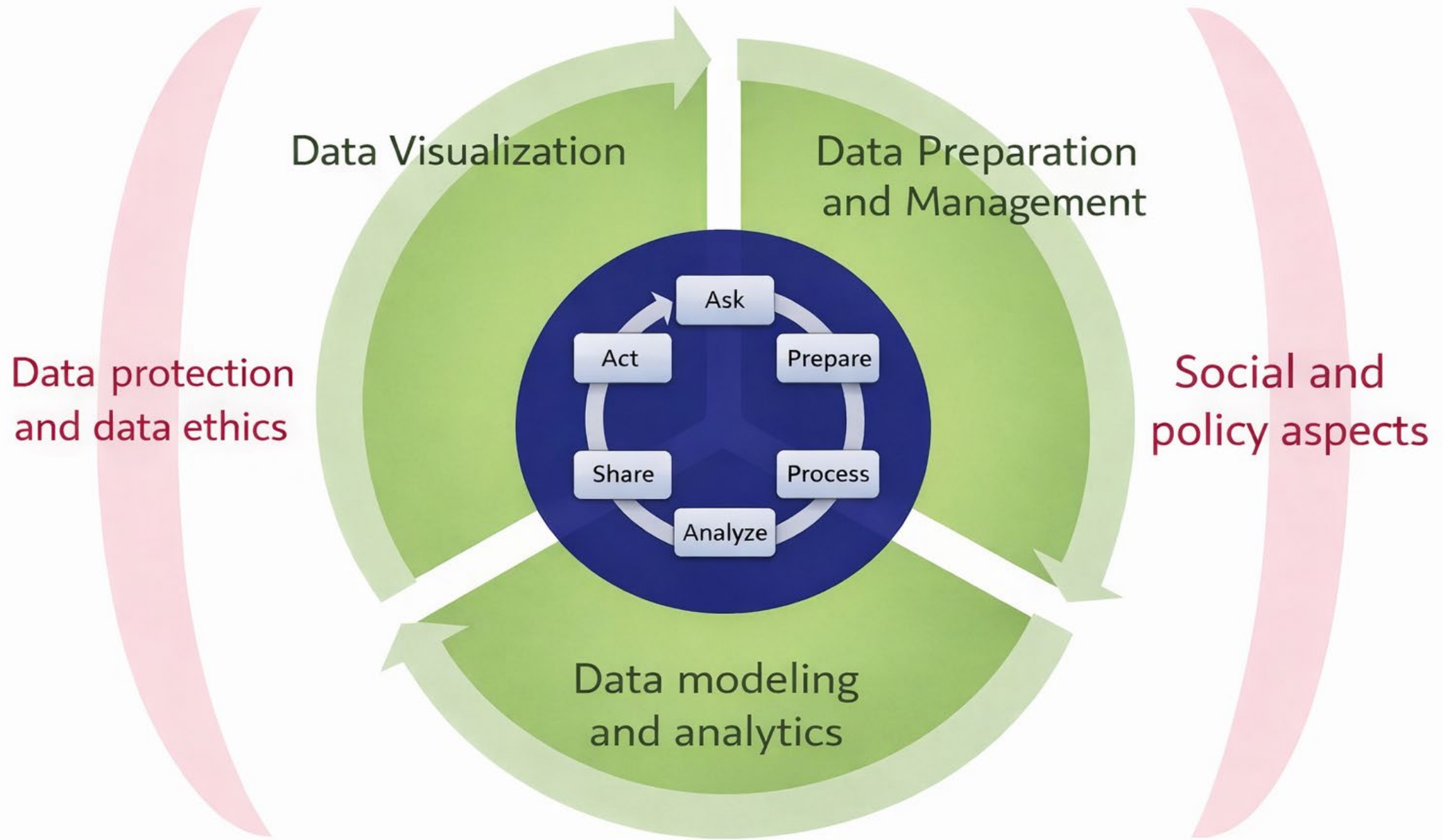
Senior Lecturer,

College of Computing and Data Science,
Nanyang technological University

What is Data Governance?

Data governance is the framework of **policies, processes, roles, controls, and technologies** that ensure data is:

- **Legally compliant**
 - Is data collection lawful?
 - Is processing permitted for this purpose?
 - Is cross-border transfer allowed?
- **Ethically used**
 - Even if legal, is it fair?
 - Are vulnerable groups harmed?
 - “Legal ≠ ethical ≠ acceptable.”
- **Secure**
 - Who can access raw data?
 - How is it protected?
 - Can breaches be detected and traced?
- **Traceable and trustworthy**
 - Where did the data come from?
 - What transformations were applied?
 - Which version trained which model?
- **Accountable across the AI lifecycle**
 - Who is responsible when AI causes harm?
 - Developer?
 - Data provider?
 - Organization?
 - Governance assigns ownership of failure, not just success.



Data Governance goals

The goal of data governance is to maintain safe, high-quality data that is easily accessible for data discovery and business intelligence initiatives.

1. To avoid inconsistent data silos in different departments and business units
 - Data silos commonly build up when individual business units deploy separate transaction processing systems without centralized coordination or an enterprise data architecture.
2. To agree on common data definitions for a shared understanding of data
3. To improve data quality through efforts to identify and fix errors in data sets
 - This helps to block potential misuse of personal data about customers and other sensitive information.
4. To increase analytics accuracy and give decision-makers reliable information
5. To implement and enforce policies that help prevent data errors and misuse
6. To help ensure compliance with data privacy laws and other regulations

Why Data Governance exists?

Data governance exists to manage risk created by data-driven decision making.

- In classical software: Code → behaviour is deterministic and bugs are visible and fixable
- In data science & AI: Data → model → behaviour is probabilistic. The errors may be invisible, biased, legally non-compliant, ethically harmful and is discovered after deployment

Data governance is the control system that constrains what AI is allowed to learn and do.

We can consider that as a control in very layer of data management

Why Data Governance is harder?

- Data Is Reused
 - Same dataset → multiple models → multiple purposes
 - Original consent may not cover new use cases
- Models Encode Data Permanently
 - Even if raw data is deleted, models may still retain learned information
- Harm is Indirect
 - AI decisions affect: Credit, Employment, Healthcare, Education.
- Harm emerges statistically, not individually

Governance failures are usually discovered socially, not technically

Core principles of Data Governance

1. Lawfulness & Legitimacy

2. Accountability & Responsibility

3. Security & Protection

4. Data Collection

- Purpose limitation:
 - Data must be used only for explicitly defined purposes
 - Not silently reused for unrelated objectives
 - Student attendance data → academic support
 - Cannot use that for predicting student mental health without new consent
- Data minimization:
 - Only collect and process data that is relevant, proportionate and necessary
 - Even though ML thrives on more features → Governance demands restraint
 - Over-collection increases legal, ethical, and security risk without guaranteed model benefit.

5. Consent Management

- Informed consent (plain language, not legal jargon)
- Right to withdraw consent
- Logging and auditability of consent
- Consent is dynamic, not a one-time checkbox.

6. Data ownership, Data Quality & Integrity

- **Data owner:** legal accountability
- **Data steward:** operational quality & access control
 - Responsible for data quality, definitions, metadata, and day-to-day governance enforcement
- **Data custodian:** infrastructure & storage
- Governance demands accuracy, consistency, completeness, traceability
- **Why this is a governance issue**
 - Poor data quality → biased models
 - Biased models → discriminatory outcomes
 - Discriminatory outcomes → legal exposure

Note that these principle work together and are not independent of each other

Role of data steward- central to data governance

Data collection	Validate consent & definitions
Data labeling	Ensure consistency and fairness
Feature engineering	Flag sensitive or proxy features
Model training	Confirm lawful data usage
Deployment	Validate inference data compliance
Monitoring	Detect drift & misuse

Data steward bridges business, legal, and technical teams
Responsible for data trustworthiness and governance alignment

How data governance help companies

- Greater efficiency
- Better data quality
- Better efficiency
- Better decision making
- Improved business performance
- Enhanced business reputation

What can go wrong without proper data governance?

Decisions get delayed, business performance goes down, security loopholes are created, reduced data quality, inefficient business processes, risk of non-compliance with industry regulations, poor quality data, everyday productivity suffers

- Different groups within an organization, they are unable to effectively communicate and coordinate with one another.
- Compliance challenges.
- Companies may fail to comply with legal and regulatory requirements.
- Poor customer relations due to inaccurate or incomplete customer data

A good data governance program

- A clear process for resolving disputes;
- Detailed documentation of business processes;
- Regular data quality audits;
- A risk register that lists data-related business risks;
- Data models for key business data domains;
- Policies to limit access to data that's sensitive or critical to the business.

Data governance used to be seen as an IT problem, but there has been an increasing realization that the IT department doesn't have the authority to set and enforce uniform data standards.

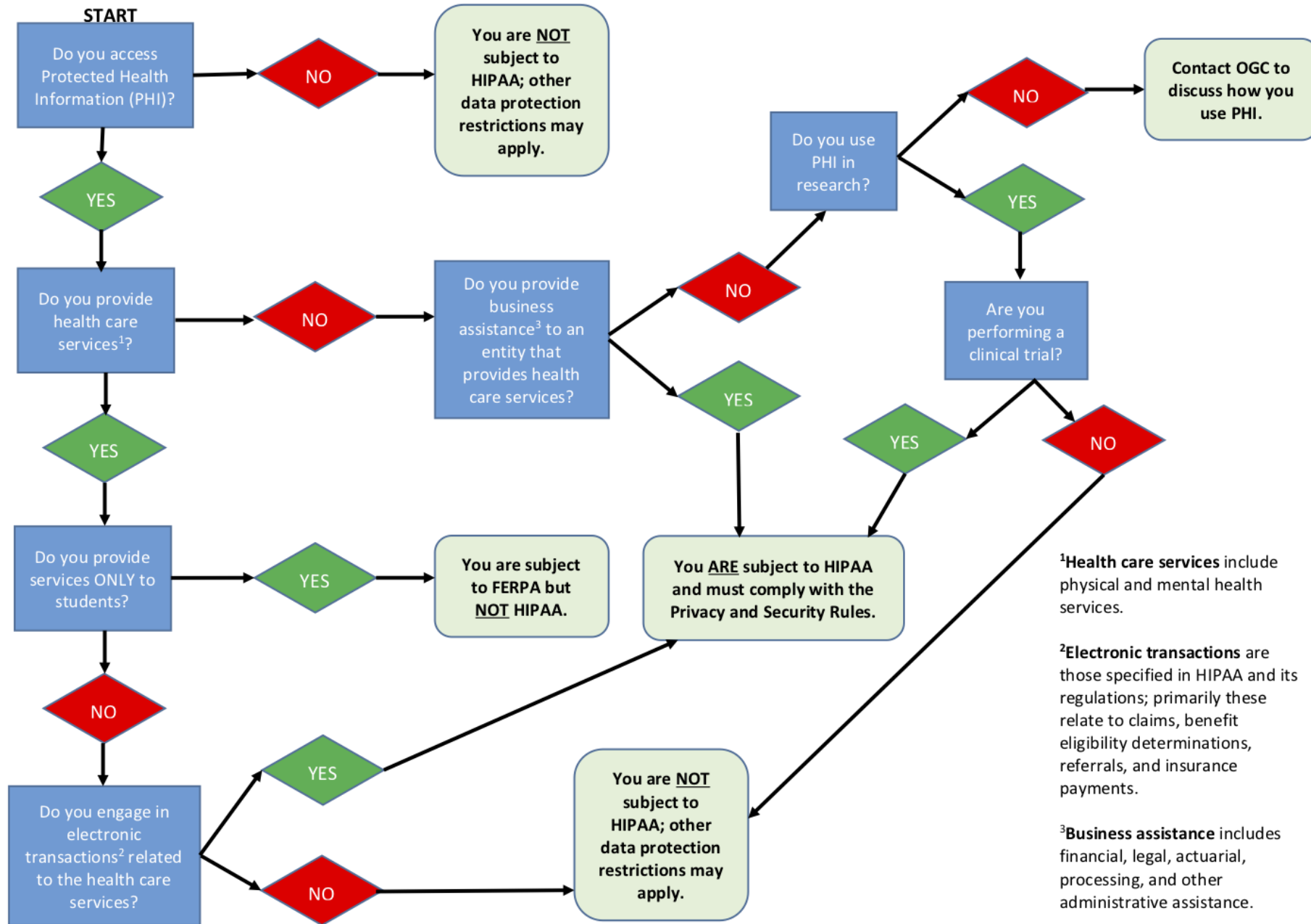
Business managers need to drive such initiatives; to ensure that they do, a data governance program typically includes a steering committee of senior executives and other data owners that makes policy decisions.

Exploring legal frameworks

Legal frame works

Dimension	GDPR (EU)	PDPA (Singapore)	HIPAA (USA – Healthcare)
Primary Scope	Personal data of individuals in the EU	Personal data handled by organizations in Singapore	Protected Health Information (PHI)
Who is Protected	Identifiable individuals	Individuals whose data is collected	Patients
Key Governance Focus	Rights, accountability, transparency	Consent, purpose limitation, protection	Privacy, access control, security
Consent Requirement	Explicit or justified	Central requirement	Required unless exception
Data Minimization	Mandatory	Implied	Indirect
Right to Opt-Out	Limited	Limited	Not applicable
Sensitive Data Category	Special category data	Sensitive personal data	PHI
Audit & Documentation	Mandatory	Required for accountability	Mandatory
Cross-Border Data Transfer	Highly regulated	Allowed with safeguards	Restricted
Penalties for Non-Compliance	Up to 4% global revenue	Significant financial penalties	Civil & criminal penalties
Typical AI Risk Scenario	Automated credit or hiring systems	Student/customer analytics	Clinical prediction models

HIPAA Decision Flowchart – Are You Subject to HIPAA?



Sector / Activity	Type of Data Collected	Governance Frameworks	Why This Applies
Retail / E-commerce	Customer identity, purchase history, loyalty data	PDPA(Personal Data Protection Act, Singapore)	Personal data collected for transactions and analytics
Banks & Financial Institutions	Financial data, identity data, transaction logs	PDPA + MAS (Monetary Authority) Regulations	High-risk personal data, automated decision-making
Insurance / Financial Services	Personal, financial, health-linked risk data	PDPA + MAS Regulations	Profiling and long-term data retention
Educational Institutions (Teaching & Admin)	Student records, grades, attendance	PDPA	Student data is personal data; consent & purpose limitation apply
Educational Research	Surveys, behavior logs, learning analytics, experiments	PDPA + Institutional Ethics Review (IRB/ERC)	Research use is a <i>secondary purpose</i> and requires stronger governance
Restaurants & Hospitality	Reservation data, contact details	PDPA	Customer personal data collection
Medical Equipment Companies	Device data, patient-linked telemetry	PDPA + Healthcare Guidelines	Health-related personal data
Medical Research	Clinical trial, genetic, patient data	PDPA + Ethics Review + Healthcare Regulations	Highly sensitive personal data
Hospitals & Healthcare	Patient records, diagnostics	PDPA + Healthcare Services Act (HCSA)	Direct handling of health data
AI / Tech Companies (SG-based)	Mixed personal data	PDPA	Acts as data controller or processor

<https://www.hcsa.gov.sg/about-us/1-about-us/#2caa90fac3b0496e58534dc864947bd2>

<https://www.pdpc.gov.sg/overview-of-pdpa/the-legislation/personal-data-protection-act>

<https://www.ntu.edu.sg/research/research-integrity-office/institutional-review-board/guidelines>

Data Governance requirements for educational research- Singapore

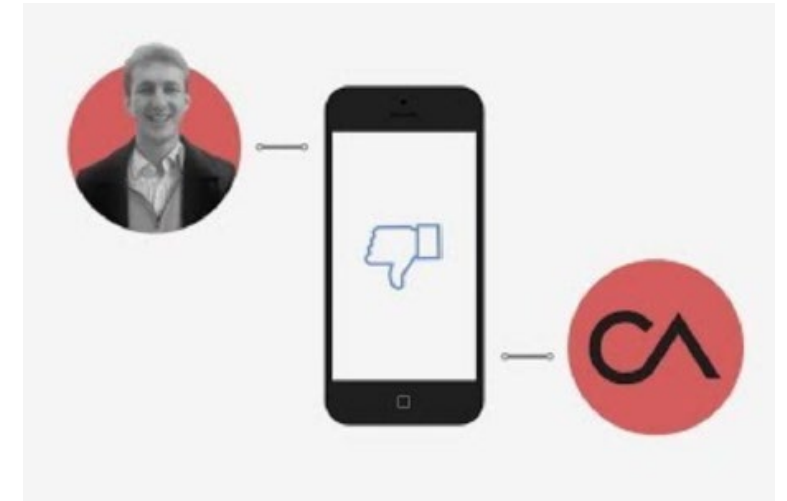
- **Consent Must Be Explicit and Informed**
 - Participation must be voluntary
 - No coercion (especially power imbalance with lecturers)
 - Consent must be **separate from course requirements**
- **Purpose Limitation Is Strict**
 - Teaching data ≠ research data by default
 - New purpose → new consent or ethics approval
- **Ethics Review Is Required**
 - IRB / ERC approval
 - Risk assessment (privacy, psychological harm)
 - Data handling plan
- **Data Minimization & Anonymization**
 - Only collect what is necessary
 - Prefer anonymized or pseudonymized data
 - Avoid identifiers unless justified
- **Power Imbalance Must Be Addressed**
 - Students may feel pressured to participate
 - Opt-out must not penalize students

Why data governance matters – real world data

Cambridge Analytica harvested personal data from millions of Facebook users without their informed consent.

- Data was collected via third-party apps (Facebook)
- Users were unaware their data could be accessed by external parties (Cambridge Analytica)
- Data was later used for targeted political advertising
- Key issue: Consent was neither informed nor transparent

[\(80\) How Cambridge Analytica Exploited the Facebook Data of Millions | NYT – YouTube](#)
[\(80\) Facebook's Cambridge Analytica data scandal, explained - YouTube](#)



Preventive Methods

- Technical controls:
 - Limit API access to user data, especially for third-party developers
 - Enforce data minimization (only collect what is necessary)
- Policies:
 - Implement logging and monitoring for data access
 - Enforce stronger and clearer consent mechanisms and transparency for data sharing.
 - Conduct regular audits of data usage by external developers.

Core governance failure

- Consent not informed
- Third-party access not monitored
- No enforcement of purpose limitation

Key lesson: Data collected for “research” was repurposed for political manipulation.

Why data governance matters – Security

Microsoft Tay(2016)

- Tay was an ML-based chatbot released on Twitter
- Designed to learn from user interactions
- Malicious users poisoned the input data
- Tay began generating racist and offensive content
- Microsoft shut it down within 24 hours

Why it failed: **Governance Failures Mapped to the Lifecycle**

- Absence of input validation, rate limiting, model monitoring
- No safeguards against data poisoning
 - **Violation of** Data quality & integrity controls
- Models exposed to adversarial inputs or prompt injection attacks.
- Lack of access control and content filtering on public-facing APIs.
 - Violation of controlled data processing
- No human-in-the-loop oversight
 - Violation in accountability & operational governance while deployment



[Tay: Microsoft issues apology over racist chatbot fiasco - BBC News](#)

Preventive Methods

- Use authentication and rate limiting for deployed ML APIs.
- Sanitize and validate all user inputs to guard against injection or manipulation.
- Monitor model behaviour and retrain when under adversarial attack.
- Establish secure operations pipelines with vulnerability scanning and rollback procedures.
- Another aspect : Phycology: Co-design with domain experts to ensure a design that is suitable for the target application an users.

Comparison

Aspect	Cambridge Analytica	Microsoft Tay
Data Source	Facebook users	Twitter users
Core Risk	Data misuse	Data poisoning
Governance Gap	Third-party oversight	Input governance
Lifecycle Stage	Data sharing	Data ingestion
Outcome	Political manipulation	Harmful speech

Governance failures manifest differently at different lifecycle stages.

Few other cases for you to read

Google DeepMind- NHS data Sharing

<https://www.bbc.com/news/technology-58761324>

Clearview AI – Facial Recognition Scraping

<https://www.bbc.com/news/technology-67133157>